

Token-Based Authentication Summary

1. What are tokens?

- Access token: short-lived token used for API requests (e.g., 15 min - 1 hour).
- Refresh token: long-lived token used to get new access tokens without logging in again (e.g., 7-30 days).

2. Why use them?

- Web sessions do not work for APIs/mobile apps (stateless)
- Security: short-lived access tokens reduce risk if stolen
- Smooth user experience: refresh token keeps user logged in

3. How it works (flow)

Step 1: Login

- User logs in with username/password
- Server generates:
 - access_token -> expires quickly
 - refresh_token -> expires later
- Tokens stored in user_tokens table
- Tokens sent to client

Step 2: Use access token

- Every API request uses access_token
- Server validates token
- If expired -> client uses refresh token

Step 3: Refresh token

- Client sends refresh token to server
- Server checks if valid -> generates new access token
- Optionally, refresh token is renewed
- User continues using API without login

4. Multi-device support

- Separate row per device in user_tokens table
- Example table:

user_id	device	access_token	refresh_token	access_expires	refresh_expires
1	PC Browser	abc123	def456	15 min	7 days
1	Mobile App	xyz789	uvw123	15 min	7 days

- Each device can stay logged in independently
- Can revoke token per device

5. Benefits

- Multi-device login [OK]
- Secure API requests [OK]
- Token expiration & refresh [OK]
- Revoke stolen tokens without affecting other sessions [OK]

6. Key points

1. Access token -> used for API requests
2. Refresh token -> used to get a new access token
3. Separate tokens table -> supports multiple devices
4. Tokens improve security and user experience